Failure-Routing in AI/ML Python Except-Handlers: Corpus Measurements and Validation Limits

Yufeiyang Chen*
School of Cyber Science and Technology, Sun Yat-sen University, Shenzhen, China
Correspondence: fei76161@gmail.com

12 October 2026

Abstract

Static detectors can identify exception handlers that turn a failed operation into an ordinary result. Establishing what those detectors add, however, requires separating warning coverage from actual contract violations. We examine that distinction through an AST-based detector, eight pinned AI/ML Python packages and paired evaluation checks. The initial frame contains 621 candidates. All 19 contextlib.suppress candidates escape four selected lint baselines, even under full-rule Ruff and default Pylint checks; a supplementary Semgrep rule reaches 18. On a refined frame, 68 generated probes and an explicit file-discovery check correct the inferred unmatched share from 18.3% to 47.1%, with the detector outputs held fixed. A separate predicate change increases measured lint overlap from 41.1% to 52.9% while reducing the covered count from 255 to 252: the changing denominator explains the increase. Nine of 14 in-scope curated merged fixes fall outside handlers, exposing a further boundary of local analysis. These results provide reproducible tests for evaluation errors that can inflate or conceal a detector's apparent increment. Coverage measurements are supported by executed checks; the separate LLM-labelled observations do not establish defect precision and require independent contract adjudication.

Keywords: exception handling; silent failure; static analysis; empirical software engineering; machine learning systems.

1 Introduction

An AI evaluator catches an API timeout and returns `0.0`. A document loader catches a decoding error and returns an empty string. In both cases, the caller receives a value it could also receive after a successful computation. The exception has been converted into an ordinary result, and downstream code must recover a distinction that the local return value no longer carries. We call this *failure-routing*. Its consequences depend on the caller's contract: a fallback may be intentional, or it may corrupt a score, a security verdict or a later computation.

Static analysis can locate candidate handlers, but evaluating such an analysis requires several distinct measurements. Does another tool flag the same site? Does a change in syntax alter warning coverage? Does a candidate violate its caller's contract? These questions use different evidence. Treating them as interchangeable can overstate a detector's incremental value or hide a gap in the comparison itself.

This study examines those distinctions through a concrete detector and pinned software artefacts. `failroute` recognises five silent-continuation or failure-to-value shapes and one adjacent exception-masking shape, including both `except` handlers and `contextlib.suppress` sites. We compare its candidates with four selected lint baselines, test the coverage mapping with generated probes, and examine how predicate refinement changes the resulting frame. LLM labels and public maintainer records provide further evidence with stated provenance and selection boundaries.

*__Author contribution.__ The author originated the `failroute` idea and directed the study, including its research questions and key decisions. AI language tools assisted software development, testing, data analysis, and the drafting and revision of the text. The author takes responsibility for the final work. Corpus labels were produced by LLM agents rather than human annotators; the paper states their provenance and limitations.

A representation-sensitive coverage boundary. Ruff's `SIM105` [2] recommends replacing a simple `try/except/pass` block with `contextlib.suppress(...)`. A direct rewrite can preserve the intended suppression while changing which warnings a tool emits. In the frozen 0.8.0 frame, none of the 19 `silent-suppress` candidates is reported by the four selected lint baselines. Enabling all 969 Ruff rules or Pylint's full default message set does not recover them. Our supplementary Semgrep rule reaches 18 of the 19 (Section 5.1). This establishes a concrete gap in the tested configurations and shows that the shape can be expressed by a syntactic rule; deciding whether suppression is appropriate remains a contract question.

Explicit handler

```
try:
    update_cache()
except Exception:
    pass
```

Suppress statement

```
with contextlib.suppress(
        Exception):
    update_cache()
```

Figure 1: Constructed illustration of the measured representation boundary. Selected Ruff S110 and Bandit B110 checks recognise the broad `except/pass` form; the four selected lint baselines do not reach the suppress form. Ruff SIM105 recommends this kind of rewrite. The example illustrates warning reach, not whether the caller's contract permits suppression.

Research questions. The study separates warning comparison from contract validation:

RQ1 Which local failure-routing shapes are reached by the selected lint baselines, and where does source representation change that reach? (Section 5.1)

RQ2 How much do candidate refinement, coverage mapping and file discovery change the measured overlap? (Section 5.2)

RQ3 What can exploratory labels and maintainer records establish about candidate validity and the detector's scope? (Section 5.3)

Contributions.

1. **A reproducible measurement of a suppression-form boundary.** An AST-based detector identifies 621 candidates across eight pinned AI/ML packages and 524,229 scanned lines. All 19 `contextlib.suppress` candidates escape the four selected lint baselines; a supplementary rule reaches 18. This characterises a representation-sensitive warning boundary in the tested configurations (Section 5.1).
2. **A paired analysis of evaluation sensitivity.** Holding the corpus fixed, we separate changes to the detector predicate from changes to its coverage measurement. A 68-probe calibration and a file-discovery check correct the inferred unmatched share from 18.3% to 47.1% without changing any detector output. Predicate refinement, by contrast, changes the frame from 621 to 476 findings while measured overlap rises from 41.1% to 52.9%. The preserved exports and executable checks make these effects traceable (Section 5.2).
3. **An explicit account of validation and construct boundaries.** Exploratory labels, a selected control corpus and curated merged fixes test different claims. Nine of 14 in-scope reference fixes route failure outside exception handlers. We identify what these records support, where they disagree with local shape-based reasoning, and what independent contract evidence a defect-detection claim would need (Section 5.3).

Study design. The comparisons answer different validation questions. Syntax witnesses and baseline checks test warning reach; generated probes test the measurement instrument itself. The paired frames then distinguish a change in candidate selection from a change in how coverage is counted. Control packages and merged fixes test the limits of handler-local reasoning, while exploratory labels identify contract questions for further adjudication. The coverage claims rest on executed scans and probe outcomes, not on treating the LLM labels as ground truth. This separation makes it possible to report an instrument correction or a counterexample without converting either into a defect-detection claim.

2 The pattern family

The six registered shapes are listed in Table 1. Five concern a caught failure that is suppressed or routed into a normal-looking value or continuation. `name-shadowing` is different: it can replace the original exception with a `NameError`, masking the cause without producing a success-shaped value. We include it as an adjacent exception-handling hazard, not as evidence of silent success. The categories describe local Python constructs; membership alone does not establish a contract violation. Their operational predicates were revised during development on this corpus. Four of the six shapes account for all 621 findings reported in Section 5.1, and the two that never fire on this corpus are retained because a shape's absence from one corpus is not evidence that the shape does not occur. Both are exercised by the tool's unit corpus.

Table 1: Five silent-continuation or failure-to-value shapes and one adjacent exception-masking shape.

Rule	Shape	Consequence
`no-action`	`except ...: pass`	handler emits no direct failure signal
`silent-fallback`	handler returns/assigns a constant without re-raising	judge outage becomes a legitimate `0.0`
`masked-exception`	catch-all conditionally re-raises *and* falls back to a constant	outcome depends on which branch ran
`silent-suppress`	`with contextlib.suppress(...)`	suppresses specified exceptions; invisible to the linters we tested
`implicit-fallback`	handler neither re-raises, returns, nor records — falls through to implicit `None`	"did nothing" becomes a legitimate `None`
`name-shadowing`	`except E as e:` rebinds `e` inside the handler	Python deletes the binding on exit; a later use can raise `NameError` or `UnboundLocalError`

3 The detector

The detector configuration defines which candidates enter the comparison. We describe its rules and exclusions so that the measurements can be interpreted. `failroute` 0.8.0 parses each file to an AST and applies six rules through a shared registry, emitting text, JSON or SARIF; individual rules can be disabled per project under `[tool.failroute]`.

Unit of analysis. One finding is one `except` handler — or, for the `silent-suppress` rule, one `contextlib.suppress` statement — reported at the line where it starts. Findings are sorted by line, with a stable per-handler registry order for findings that share a line, so the output order is deterministic.

What counts as silence. The tool treats a failure as explicitly signalled, rather than silently routed, if its handler re-raises; calls `exit` or `_exit`; calls `warnings.warn` or `warnings.warn_explicit`; or calls a logger-like name. Two properties of that test matter for reading Section 5.3.1.

First, the test is *not* uniform across handler kinds. A **catch-all** handler (bare `except:` or `except Exception:`) must call a method named in {error, warning, warn, exception, critical, fatal}; a **typed** handler qualifies on *any* method of a logger-like object, `debug` and `info` included — and, because the test matches the object rather than the method's meaning, on method names that are not logging calls at all. `capture_exception` on a logger-like object also qualifies. A bare `print()` never does. Thus `logger.debug()` prevents a finding for a typed handler under this syntactic test but not for a catch-all handler. The asymmetry is deliberate: a typed clause documents the failure its author anticipated. It does not establish that a debug message reaches the caller. Section 5.2 shows the asymmetry matters in this sample: every original LLM DEFECT label sits on a bare handler, which falls through the strict half of this test rather than the lenient half.

Second, the test is not global. Only `silent-fallback` and `implicit-fallback` consult it; `no-action`, `masked-exception` and `name-shadowing` report without asking whether the handler recorded anything.

"Logger-like" means a base-name list (`logger`, `logging`, `log`, `_logger`, `_log`, `sentry_sdk`) plus a suffix heuristic, since real codebases name loggers `audit_logger`, `err_log` and `self._log`. Handler bodies are traversed through control flow but *not* into nested function, lambda or class bodies, so a `return None` inside a callback defined in a handler does not silence it.

What counts as a fallback value. A fixed constant set (`None`, `False`, `0`, `0.0`, `""`, `[]`, `{}`, `()`), whose ambiguous members (`True`, `1`, `1.0`) are marked as such because they are legitimate in boolean scorers, plus namespace-qualified sentinels such as `Status.UNKNOWN` and any project-specific values configured under `[tool.failroute]`. Bare names are deliberately not matched, so `return result` can never fire.

Exemptions. Three gates remove a site before any rule runs. The first is the caught type. A handler catching only `KeyboardInterrupt`, `SystemExit` or `GeneratorExit` is exempt. The same applies to `StopIteration`, `StopAsyncIteration` or `CancelledError`; a tuple handler is exempt only when every member is. These exceptions can occur in shutdown, iteration and cancellation handling, where suppression may be intentional; the tool does not determine whether it is appropriate at a given site. The exemption can therefore also hide a genuine mistake. The second gate is an opt-out marker in the handler's own lines: `# failroute: ignore` or `# pragma: no cover`. The third is configuration: a rule disabled under `[tool.failroute]` never fires. All three gates are applied once, in the dispatcher, rather than re-implemented per rule.

The heuristics deliberately err on the side of reporting: a finding is meant to be worth a look, not to be a verdict. Section 5.3.1 reports LLM labels for a sample; those labels do not measure precision against confirmed defects.

Quality gates. The v0.8.0 release has 158 tests and a CI matrix covering Ubuntu, macOS and Windows with Python 3.9–3.13, plus `mypy --strict`. Its v6 unit-fixture corpus contains 36 positive and 32 negative cases; CI checks each against its expected result.

Construct validity. Fixture agreement shows that the detector implements its tested specification; it does not show that its findings are real defects. Section 5.3.1 is a limited within-corpus label audit, not an external validation against confirmed defects.

4 Study design

Statistical reporting. The paper reports finite-set counts and descriptive proportions. The weighted label projection estimates the number of LLM DEFECT labels in its corrected sampling frame; it is not an estimate of confirmed defects. The package, co-location, and PR comparisons have different sampling or selection processes and are not used to infer population rates or causal effects. No confidence intervals are reported because the available labels and selected records do not support the population claims such intervals might suggest.

4.1 Corpus

Eight AI/ML packages fetched as pinned PyPI source distributions (not git clones), each recorded with URL, SHA-256, upload time and extracted tree hash in `paper/corpus-lock.json`. Table 2 lists them. Together the eight sdists hold 2,354 `.py` files and 563,270 lines; the scan roots the detector actually reads hold 2,124 files and 524,229 lines; finding-density figures are calculated over those scan roots. Fetching is pinned rather than merely scripted: `tools/fetch_corpus.py` resolves each package to the version recorded in `paper/corpus-manifest.json`, checks the downloaded archive's SHA-256 against the same manifest, and exits non-zero on mismatch, so a re-fetch either reproduces these inputs or fails loudly. A fresh fetch into a clean directory on 2026-09-02 reproduced all eight archives byte-identically (8/8 SHA-256 matches against `corpus-lock.json`).

A second, style-opposite corpus tests whether the headline comparison survives outside bare-`except` code. Eight infrastructure packages were fetched as pinned PyPI sdists (URL, SHA-256, upload time and tree hash in `paper/corpus-lock-control.json`, same schema as above): `attrs` 26.1.0, `httpx` 0.28.1, `requests` 2.34.2 and `urllib3` 2.7.0 (the four zero-bare-`except` packages of Section 5.2.1), plus `click` 8.5.0 (CLI), `pydantic` 2.13.5 (validation), `anyio` 4.15.1 (concurrency) and `msgpack` 1.2.2 (serialisation) — chosen for domain diversity before any scan ran, explicitly avoiding the HTTP-client stack that three

Table 2: Pinned corpus. Per-package counts are the files *inside each scan root* — the subtree the detector actually scans — so the column sums to the total shown (2,124 `.py` files / 524,229 lines). The eight pinned sdists contain **2,354** `.py` files / **563,270** lines in total; the difference is content outside the scan roots (tests, examples, vendored code).

Package	Version	Scan root	`.py` files	Lines
inspect_ai	0.3.260	`src/inspect_ai`	755	198,351
pydantic_ai_slim	2.36.0	`.`	298	119,534
deepteam	1.0.9	`deepteam`	588	71,305
trl	1.12.0	`trl`	155	65,727
garak	0.16.0	`garak`	201	38,328
smolagents	1.26.0	`src/smolagents`	20	13,355
uqlm	0.6.5	`uqlm`	91	12,605
fickling	0.1.12	`fickling`	16	5,024
Total (scanned)			**2,124**	**524,229**

of the first four share. Only each package body is scanned (scan roots recorded in the lock file), the same definition as above. Section 5.2.1 reports the comparison.

Measurements and units. A *finding* is a rule output; a *site* is its source coordinate, so two outputs at one handler remain one site. Warning overlap is co-location under the declared matching rule. A label is an automated reading of a sampled candidate, whereas a merged fix is a selected change accepted by a maintainer. Table 3 distinguishes these units before we compare them.

Table 3: Evidence used in the study and the claim each measurement supports.

Measurement	Observation	Interpretation
Representation	19 suppress candidates; 0 reached by selected lint baselines, 18 by the supplementary rule	warning reach under pinned configurations
Predicate refinement	621 to 476 findings; overlap 255 to 252	candidate-frame change
Mapping calibration	87 to 224 unmatched findings on the same 476-finding frame	measurement correction
Contract labels	80 stratified and 60 purposively selected LLM readings	exploratory contract evidence
Curated fixes	9 of 14 in-scope merged fixes are outside handlers	scope boundary in a selected set

5 Results

5.1 RQ1: Warning coverage and representation

`failroute` (v0.8.0) reports **621** findings. Baselines were run on the *same* pinned trees; Table 4 lists the tools, their versions and the rule sets they were invoked with.

Matching protocol. Each baseline was invoked with only the rules that address this family — `ruff` S110/S112, `bandit` B110/B112, `pylint` W0702/W0703/W0705/W0706, `flake8` E722 with `bugbear` B001/B017 — and every report was reduced to a (file, line) pair. A `failroute` finding counts as *covered* by a baseline when that baseline reported any of its selected rules in the same file within ±1 line of it (`TOL = 1` in `tools/coverage_union.py`), and as covered by the *union* when any baseline covers it. Co-location is deliberately a weak criterion — it asks whether a tool flagged the same handler, not whether it expressed the same property — and the caveat at the end of this subsection states what that costs.

A blind spot in the baseline harness and its correction. The initial harness passed each scan root to `pylint` as a single directory argument. `pylint` walks a directory as a *package* and does not descend into one with no `__init__.py`, so every module under such a directory is silently never analysed — no message, no error, exit 0. Here 152 of the 2,124 scanned files (7.2%) sit under one (`inspect_ai` 123, `deepteam` 20, `garak` 9), and RQ1's exact selection emits 34 messages across 20 of them that the directory invocation reported as zero. Handing `pylint` the file list recovers them and perturbs nothing else: on the files it already reached, the two invocations agree message for message (0 lost, 0 gained, per package), so the correction is a pure addition to the baseline. Every figure in this paper uses the corrected invocation, and it moves the four-linter union from 250 to 255 of 621 and `failroute`-only from 371 to 366 — it *reduces* the detector's unmatched warning count. Reporting the corrected read set is therefore necessary for a valid comparison. The other three baselines have no equivalent blind spot: `ruff`, `bandit` and `flake8` are filesystem walkers, and over those same 152 files their directory and explicit-file invocations return identical hit sets — 6,879 messages under `ruff --select ALL`, 104 under `bandit` with every test enabled, and 2,375 under `flake8`'s default selection, identical both ways. Under RQ1's own narrow selections those same files yield 5, 0 and 0, which is why the blind spot cost only `pylint` anything. The control corpus of Section 5.2.1 contains no `__init__`-less directory at all (0 of 263 files), so it was never exposed. `--recursive=y` and `--init-hook` were both tested; neither recovers a single message.

The baseline selection includes Pylint's W0703 (broad `except`, reported as W0718) but excludes Ruff's direct analogue BLE001. We checked this asymmetry with an additional selection that includes BLE001. Re-running with BLE001 added, `ruff`'s *own* co-located findings rise from 72 to 127 (410 findings in total rather than 76), but the four-tool union does not move: 255 of 621 and `failroute`-only 366 under either selection, because every finding BLE001 newly reaches is one `pylint`'s W0718 already reaches (W0718 is the id under which `pylint` reports the retired W0703 that the baseline enables). `silent-suppress` stays at 0/19 either way, since BLE001 fires on `except` clauses and the shape in question has none. The asymmetry therefore costs the union nothing and bears only on the per-tool comparison below; we keep the narrower selection as the headline because that is what the publicly tagged artefact set reproduces. The symmetric run is `tools/coverage_union.py --ruff-select S110,S112,BLE001`, and its output is committed as `bench/corpus-coverage-union-ruff-ble001.json`.

Table 4: Cross-tool comparison on the pinned corpus. The `semgrep` row is *not* a shipped-rule baseline: its rule set (`tools/semgrep-rules/exception-handling.yaml`) was written by us, so it shows what a syntactic-pattern engine *can* express given rules, not what users get by default. +19 is the number of `failroute` findings newly co-located once `semgrep` is added to the union (mostly the `contextlib.suppress` shape: 18 of 19).

Tool	Version	Rules	Findings	Co-located ±1 line
`failroute`	0.8.0	all six	**621**	—
`ruff`	0.16.4	S110, S112	76	72
`bandit`	1.9.4	B110, B112	67	63
`pylint`	4.0.8	W0702, W0703, W0705, W0706	563/564	255
`flake8+bugbear`	7.3.0 / 25.11.29	E722, B001, B017	268	124
`semgrep` (our rules)	1.175.0	hand-written, 6 shapes	—	+19

Baseline version and environment provenance. Versions are those installed in the reproduction environment and are the versions that produced the committed artefacts. Three provenance notes. `pyproject.toml` pins `ruff==0.16.5`, one patch above the 0.16.4 that produced the committed artefact; 0.16.0, 0.16.4 and 0.16.5 all produce *set-identical* hits for both rule selections (76 findings and 72 co-located for S110/S112; 410 and 127 for S110/S112/BLE001), so the row is stable across every patch release we can install. The `pylint` *Findings* cell is the one count in this table that depends on the analysis environment rather than on the corpus: `pylint` resolves imported names, so a handler that re-raises before a later `except Exception` is correctly left alone when the caught type is importable and reported as `W0706` when it is not. With `click` present, `pylint` reports 563 findings; without `click`, as in the documented install, it reports 564 and the hidden-file count above reads 35 across 21. Table 4 gives these values in that order. Co-location is unaffected — 255, and identical rule by rule, either way — so

no figure in this paper moves. And `semgrep` does not appear in `pyproject.toml` at all: the five-tool row is a frozen artefact (`bench/corpus-coverage-union-5tool.json`), not a step the documented install reproduces. Its generator, `tools/run_semgrep_baseline.py`, reads the v0.7.0 frame and writes over that artefact, so it reproduces neither the row nor the file: do not run it against the committed export.

The four selected syntactic linter rule sets co-locate with 255 of 621 findings (41.1%); 366 (58.9%) have no such co-location. Adding our `semgrep` rules raises the co-located count to 274 (44.1%) and lowers the unmatched count to 347 (55.9%). These are exact corpus counts under the stated matching rule, not estimates of equivalent detection. Table 5 breaks them down by rule and Figure 2 plots them.

Table 5: Per-rule co-location counts under the stated ±1-line criterion. The four-tool union includes `ruff`, `bandit`, `pylint`, and `flake8` with `bugbear`; the next column adds the project's supplementary `semgrep` rule. The two zero-count families remain in the detector but do not occur in this corpus. For `silent-suppress`, none of the selected rules, nor the full `ruff` and `pylint` rule sets, reports a relevant warning on the 19 findings; the project rule co-locates with 18.

Rule	Findings	Four-tool union	With semgrep	Not co-located with four
`silent-fallback`	386	180	181	206
`no-action`	213	72	72	141
`silent-suppress`	**19**	**0**	**18**	**19**
`masked-exception`	3	3	3	0
`implicit-fallback`	0	—	—	—
`name-shadowing`	0	—	—	—

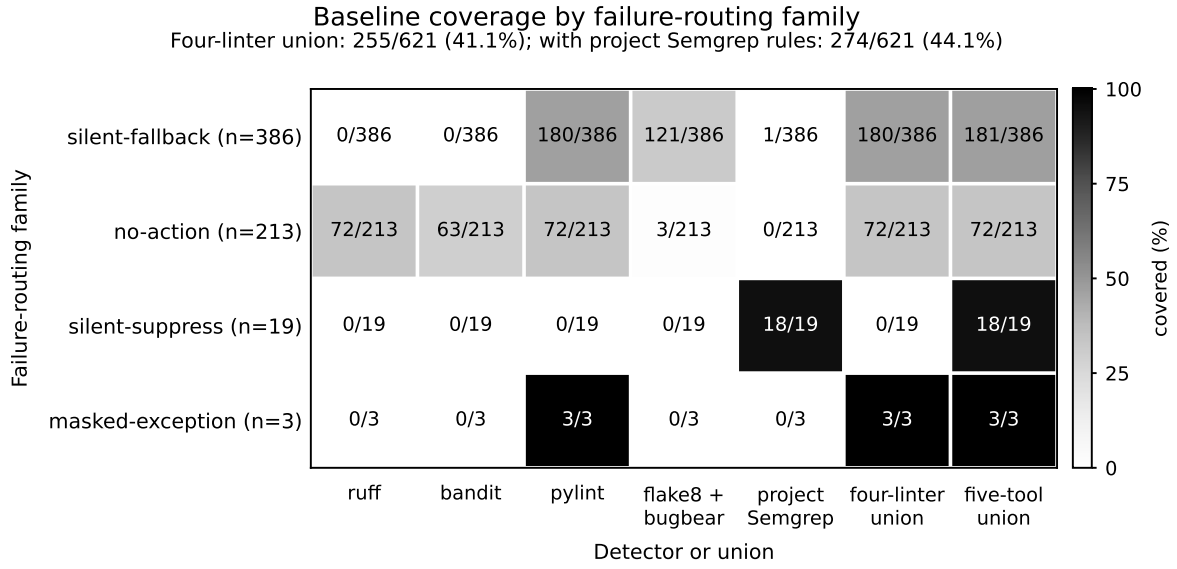


Figure 2: Coverage of the 621 pinned findings by rule family and detector. Each cell gives covered findings / family total; shading encodes the coverage share. The four-linter union covers 255/621 findings; adding the project's supplementary `semgrep` rules covers 274/621. `silent-suppress` is the one family where the four linters, `ruff`'s full 969-rule set and `pylint`'s full default set all return zero coverage.

Per-tool comparison and simple-baseline controls.

1. `pylint` is a stronger baseline than `ruff`, by a factor that depends on which `ruff` rules the comparison allows. Against `ruff`'s S110/S112 alone, the gap is 3.54× (72 vs 255 co-located findings). Adding `ruff`'s broad-except rule BLE001, symmetric to the W0703 `pylint` rule, reduces the gap to 2.01× (127 vs 255). The comparison depends on the stated rule selection; we report both rather than treating the narrower one as representative of `ruff`'s broad-except coverage.

2. `masked-exception` is fully covered. All 3 findings co-locate with a `pylint` broad-except warning. That rule contributes no additional warning coverage here; this finite count is specific to the pinned corpus.

A simple baseline for candidate-list length. The union above asks which detector findings a linter flags near the same line; it does not compare candidate-list lengths. Across the same eight scan roots, `flake8 --select E722` reports **134** bare-except candidates, including all **12** original LLM DEFECT-labelled sites. Its list is 4.63× shorter than the 621-finding v0.8.0 list and 3.55× shorter than the 476-finding refactored list. These are list-size comparisons at equal coverage of the twelve original labels, not equal recall of confirmed defects. The sample was drawn from `failroute` findings, not from E722's candidate list, so it cannot estimate E722's label yield or precision.

`ruff`'s broad-except rule BLE001 is a useful contrast: it returns 334 candidates and co-locates with none of the 12 original LLM DEFECT-labelled sites. BLE001 fires on `except Exception:`, not bare `except:`; all 12 labels in the frozen sample are attached to bare handlers. This is a finite overlap result, not evidence that E722 detects confirmed defects better than BLE001.

Both counts come from `tools/e722_baseline.py`, which fails loudly if either linter is unusable rather than reporting an empty hit set, and are committed as `bench/e722-baseline.json`.

Methodological caveat on co-location. Co-location at ±1 line means that a selected lint rule flags the same handler; it does not show that the warning expresses the failure-routing property studied here. A broad-except warning can co-locate for a different reason. We therefore report the 255/621 co-location count as such and do not infer semantic coverage or novelty from it.

5.2 RQ2: Sensitivity to the detector and its evaluation

Provenance and evaluation scope. The baseline frame uses `failroute` 0.8.0, pinned by the `v0.8.0` tag. This comparison evaluates the released `failroute` 0.9.1, pinned by `v0.9.1`; a rescan of the pinned corpus reproduces the 476-finding export in `bench/rescan-v2/` (verified 2026-09-07). The refactor was developed against the same corpus and all 140 labels used in this evaluation, with no held-out set. The results below are therefore descriptive of this development corpus and do not establish performance on unseen data.

What changed. v0.8.0's `silent-fallback` rule asks whether the handler's body returns or assigns a member of a fixed constant set. That is a syntactic proxy for the failure-to-value pattern in Section 2; it cannot tell whether the value is an intentional part of the function's contract. The refactor replaces the constant test with three further heuristics. **(1) Value-range membership:** if the enclosing function's declared return type admits the substituted value, the tool treats this as possible contract evidence and downgrades the finding — applied only to the return channel and only to explicitly declared ranges, never to an assignment into object state. A type annotation alone neither establishes intent nor lets the caller distinguish a failed operation from a legitimate value of the same type. **(2) Exception–predicate isomorphism:** whether the handler's work is structurally the same as a `-> bool` predicate the codebase already declares. **(3) Data-flow consequence:** whether the substituted value escapes the call (returned) or outlives it (assigned to object state), a proxy for possible caller-visible consequences rather than proof of them. Every finding now also carries a severity (INFO, LOW, MEDIUM, HIGH), an isomorphism class, and a static `covered_by` list predicting which lint rules flag this handler. That list is a table derived by running the four baselines over generated probes rather than by reading rule names (`tools/lint_mapping_probe.py` → `bench/lint-rule-mapping.json`). The original shape-based mapping got three conditions wrong; the calibration below reports the correction and its effect.

Candidate and overlap changes. Findings fall from 621 to **476** (617 to 472 distinct handler sites; four sites are reported twice in *each* frame, because the assign channel emits one finding per assigned target while the finding identifier is derived from the handler alone — an identifier collision in the refactored detector, noted rather than hidden). The four-linter union's co-location with those findings **rises** from 255/621 = 41.1% to 252/476 = **52.9%**; the unmatched count falls from 366 (58.9%) to **224** (47.1%). These are exact counts in the pinned corpus under the stated matching rule.

The refactor is not a pruning of the old frame, and treating it as one would overstate its coherence. Over distinct sites, **184 disappeared, 39 appeared and 433 persisted**. Of the 184 dropped sites,

155 (84.2%) had been `failroute`-only; of the 39 added, 15 (38.5%) were. The losses concentrate in `silent-fallback` (177 of 184, plus 4 `no-action` and 3 `silent-suppress`); the additions are all `silent-fallback`. `silent-suppress` falls from 19 findings to 16, so RQ1's "0 of the 19" is a property of v0.8.0 and does not carry over to this frame. On these counts, the refinement reduced the candidate list and also reduced the number of findings not co-located with selected linters. The available label set cannot establish whether that trade-off improved confirmed-defect detection.

Separating denominator and covered-count effects. Write the overlap as $O = C/N$, with C co-located findings and N findings in the frame. For the two detector versions,

$$O_1 - O_0 = \frac{C_1 - C_0}{N_1} + C_0 \left(\frac{1}{N_1} - \frac{1}{N_0} \right).$$

With $(C_0, N_0) = (255, 621)$ and $(C_1, N_1) = (252, 476)$, the smaller frame contributes $+12.51$ percentage points and the change in covered count contributes -0.63 points, giving the observed $+11.88$-point overlap change before rounding. Thus overlap rises while the number of co-located findings falls. This decomposition describes a ratio change; it does not assign causal effects to individual predicate heuristics.

Exploratory label comparison. The baseline comparison measures candidate-list co-location; the label audit reports LLM labels for a different sample. Neither alone establishes which findings are defects. We joined all 140 labels to the refactored frame on (package, file, line) — the handler's coordinates, deliberately *not* including the rule name, because the refactor can reclassify a handler without dropping it and one label in the sample was reclassified from `implicit-fallback` to `silent-fallback` — 104 join and 36 do not; all 36 come from the frozen 80 and are 33 CONTRACT plus 3 FALSE POSITIVE, so **no observation carrying an LLM DEFECT label was removed**, and only one of the 36 sits within two lines of a surviving finding — the failures to join are deletions, not line drift.

Table 6: LLM DEFECT labels by lint co-location among the 104 observations that join to the refactored frame. The static mapping and empirical co-location agree on all 104; the label shares describe this clustered, partly purposive set only.

Co-location	LLM DEFECT labels	n	Sample share
A linter reaches the finding	12	48	25.0%
No linter reaches the finding	1	56	1.8%

Because the labels are clustered and the 60 supplementary observations were purposively selected, the table describes this joined set only. It does not establish a population-level difference or incremental defect yield.

Calibrating the predicted coverage map. The inference credited `bandit:B110` and `ruff:S110` to every handler with an inert body, without looking at what the handler catches. Both rules are broad-only. Before the mapping was measured, the faulty inference called 87 of 476 findings (18.3%) unmatched, compared with co-location's 224 (47.1%), and 137 findings it called statically covered were flagged by no linter at all. One of them is `garak/analyze/ci_calculator.py:40`, whose handler is a literal `except (ValueError, TypeError): pass`. Running all four baselines on that single file returns *nothing* — `ruff` reports "All checks passed!", `bandit` and `flake8` return no rows, `pylint` scores the file 10.00/10. The incorrect mapping overestimated baseline coverage and understated failroute's incremental warning coverage. The preserved pre-fix export makes the correction auditable.

`tools/lint_mapping_probe.py` generates 68 probes — eleven caught-type forms (bare; `Exception`; `BaseException`; `builtins.Exception`; a tuple of two narrow names; a tuple mixing `Exception` with a narrow name, with a dotted name, and with a name no resolver can read; a single narrow name; a dotted narrow name; and a caught type that is a call expression) crossed with six body forms (`pass`, `...`, `continue`, a returned constant, an assigned constant, a discarded comparison), plus both `contextlib.suppress` forms — runs all four baselines over them, attributes every hit to the case whose function span contains it, and writes the matrix to `bench/lint-rule-mapping.json`. Every rule carries a positive control, so a selector that silently matches nothing fails the run instead of being recorded as "never fires". Two selector behaviours illustrate why the controls are needed. `ruff` rejects an unknown

selector with exit code 2 rather than an empty result set. And `pylint` accepts `W0703` — the retired id RQ1's baseline enables — and reports those messages as `W0718`: enabling only `W0703` emits `W0718` and nothing else, and over the corpus RQ1's exact selection emits 423 `W0718`, 134 `W0702` and 6 `W0706`, which is the 563 of Table 4. A reproducer who counts `W0703` messages finds zero and would reasonably conclude the broad-except rule never ran.

The measurement identified three incorrect mapping conditions:

- **Caught type, ruff.** `S110` and `S112` fire when the handler is bare or catches `Exception` / `BaseException`, including inside a tuple of any composition.
- **Caught type, bandit.** `B110` and `B112` are narrower still: bare, or *exactly* `except Exception:`. They do not fire on `except BaseException:`, on `except builtins.Exception:`, or on any tuple. Gating all four rules on one "broad" predicate would have moved the over-credit rather than removed it, and left `pydantic_ai/_agent_graph.py:205`, an `except BaseException: pass`, wrongly credited.
- **Body form.** `S110` and `B110` are literally "try-except-*pass*": they fire on a body of `pass` and not on a body of `...`, even for a bare handler. This detector's own notion of an inert body accepts both forms, so the distinction had to be made in the mapping rather than inherited from that flag. On this corpus that third condition changes no number — all 146 over-credited findings have a `pass` body — but it is a real defect and the probe pins it.

Correcting the caught-type conditions exposed an error in the opposite direction. The predicate deciding whether a handler catches `Exception` gave up entirely when any member of a caught tuple was not statically resolvable, so `except (anyio.get_cancelled_exc_class(), Exception):` — three instances in `inspect_ai` — was classified as narrow and kept only its body-form credit (`bandit:B110`, `ruff:S110`), losing the two caught-type credits that do fire on it (`pylint:W0718`, `ruff:BLE001`); and `bandit:B110` should not have been there either, since B110 fires on no tuple at all. That error overstates the unmatched share and would bias the comparison in favour of the tool.

The correction is checked by 36 regression tests. To test whether the suite distinguishes the corrected mapping from its predecessor, `tools/refix_replay.py` rebuilds the pre-correction predicate in a scratch tree: 21 of the same 36 tests fail on that version, whereas all 36 pass on the corrected version.

Before and after. The correction removes credit from **146** findings and adds it to 3. Of the 146, **137** become predicted unmatched and 9 stay covered because a rule that genuinely fires on them is still credited. All 146 are `no-action` findings — 93 at INFO, 48 at MEDIUM and **5 at HIGH**. Predicted unmatched findings go from 87 (18.3%) to **224 (47.1%)**, and HIGH findings with no lint coverage from 20 to **25**. What the detector *reports* does not change at all — 476 findings before and after — and neither do the empirical co-location figures (252 covered, 224 unmatched), because those come from running the linters rather than from inferring anything about them. That the predicted unmatched count and the empirically unmatched one are now the same number is not a coincidence; see the next paragraph. `tools/rq5_refactor_delta.py` recomputes the whole comparison from the preserved pre-fix export; `tools/lint_mapping_probe.py --check-parity` re-derives the mapping and fails if the shipped inference drifts from it; and 36 tests pin the same conditions, including the reverse direction (a narrow handler must lose the credit, and widening it to bare must restore it).

Resolving the remaining coverage discrepancy. Five findings of the 476 disagreed with the empirical measure. All five are `except Exception:` handlers that return or assign a constant; the corrected inference credits `pylint:W0718` and `ruff:BLE001`, `BLE001` does fire at exactly that line, and yet the co-location run recorded no linter there at all. Three explanations were tested and ruled out: it is not a parse failure (`pylint` rates `model/_providers/openai.py` 9.96/10 with no fatal or syntax message, and the file's single `except Exception` is the one it declines to flag); it is not an inline pragma (none of the four files contains the string "pylint"); and it is not the `as` binding, which real code uses and the probe originally did not — tested directly, `W0718` fires on `except Exception:`, on `except Exception as e:` and on the same handler that uses `e`, and does not fire on a bare `except:`. The synthetic case that matches these five *does* earn `W0718` in the probe, so the discriminating condition was something about their context. It was our harness, not the linter: all four files sit under a directory with no `__init__.py`, and the directory-based invocation of `pylint` described in Section 5.1 did not analyse them. Handed the files directly, `pylint` emits `W0718` at the disputed line in every one of the five. Two corrections follow. First, with the harness fixed, the static `covered_by` mapping and empirical co-location agree on all 476 findings: 224 are unmatched by both criteria. Second, this reverses the direction of the residual bias. `W0718` is in RQ1's selected `pylint` rules and fires on all five disputed handlers, so the directory-based run under-counted linter coverage and overstated unmatched coverage

by five findings (229 before correction, 224 after). None of the five was labelled, so the 12-of-48 versus 1-of-56 crosstab is unchanged.

The corrected static mapping agrees with empirical co-location on all 476 findings. The mapping repair changed coverage classifications but did not change the LLM-label join: none of the five disputed handlers carried an original DEFECT label. Among the original labels, no narrow-typed handler carried that label; one of 23 purposively selected supplementary labels on narrow-typed handlers did. This contrast does not support generalisation.

Contribution of the isomorphism layer. Of the 476 findings the isomorphism layer classified **none** as isomorphic: 254 non-isomorphic, 206 unknown, and 16 with no class at all (the `silent-suppress` findings, which have no handler). A layer that never produces a positive classification contributed nothing to the separation measured above; whatever the refactor achieved came from layer 1 (declared value ranges) and layer 3 (escape channel). Severities across the frame: 208 HIGH, 126 MEDIUM, 129 INFO, 13 LOW.

Label disposition after refinement. All 13 observations carrying LLM DEFECT labels survive it, and all 13 receive HIGH severity; this describes label disposition, not confirmed defects. Of the 122 CONTRACT labels, 33 were dropped and 25 reduced to INFO or LOW: 58 of 122, 47.5%. Restricting to the case layer 1 was built for, contracts whose enclosing function *declares* a None-admitting return type, 35 of 38 (92.1%) were dropped or reduced; for a literal `-> None`, 22 of 23 (95.7%). Not all of them, and the exceptions are the interesting part: three declared-contract findings still report at HIGH or MEDIUM, and **two** labelled FALSE POSITIVES survive at HIGH. One is `pydantic_ai/ui/_event_stream.py:293`, an async generator whose handler propagates the error elaborately and which the refactor reports *twice*. The other is `fickling/polyglot.py:150`, which the frozen sample labelled as an `implicit-fallback` over-call and the refactor now reports as `silent-fallback` instead, still at HIGH. The second one is visible only because the label join above keys on the handler's coordinates and not on the rule name: a rule-inclusive join counts a reclassified handler as a deletion and quietly reports one surviving false positive instead of two. And 55 of the 122 CONTRACT labels sit in functions with no declared return annotation at all, so layer 1 cannot apply to them by construction. That is the ceiling on how much noise this design can remove: without type information, the declared-contract test has nothing to read.

The 60 supplementary labels. The original 80 labels were drawn from the v0.7.0 frame; 72 survive into v0.8.0 and fewer into this one, which is too small a base for a crosstab. We labelled 60 further findings, written to `paper/annotations-v2-additions.csv` — a new file. The frozen `annotations.csv` and `annotations-second-pass.csv` are unchanged and remain SHA-locked; none of those observations was re-labelled to suit this section. Method: candidates were drawn from the refactored frame with priority on sites whose status the refactor changed and on sites no linter reaches; each was labelled by reading the pinned corpus source, and the detector's own severity, isomorphism and `covered_by` values were recorded into the row *after* the rationale was written, so the rationale is not a restatement of the verdict; every row carries its rationale, the enclosing signature, and a flag for whether the site is new in this frame. One row is marked in its own rationale as the weakest of the 60 — a borderline CONTRACT that a second annotator could reasonably call DEFECT — rather than being quietly resolved. The outcome was 1 DEFECT, 58 CONTRACT, 1 FALSE POSITIVE. Labels were written by an LLM agent, the same process as the original audit's, and inherit every limitation the original audit states about it, including that agreement between runs of one model family is compatible with shared bias, not proof of accuracy; we did not run the 60 twice. The 60 are *not* a random sample, so the 140-label figures support a within-sample description only, not a wider inference.

The one DEFECT label in the unmatched remainder. The single DEFECT label among the 56 non-co-located observations is `garak/probes/dan.py:134`, a narrow-typed handler from the supplementary round. It is one LLM label from a purposively selected sample, not an independently confirmed finding or an estimate of defect share. It shows only that the observed unmatched cell was not empty of DEFECT labels.

5.2.1 Control-corpus comparison

Design. The main corpus is dominated by one handler shape: 134 bare `except:` clauses, 131 of them in a single package, holding all 12 original DEFECT-labelled sites. Any claim of the form "the lint

baseline already covers the defects" may therefore be an artefact of code style rather than a general fact. The control corpus inverts the style: across its eight package bodies (263 `.py` files, 109,400 lines, 842 handlers) there is exactly one bare `except`, in `msgpack/fallback.py:812`, whose handler resets the buffer and re-raises — so even the single E722 candidate is a non-defect. The detector build is the frozen 0.9.x predicate, unmodified; the four baselines run with RQ1's exact rule selection and ±1-line matching. The four first packages contribute 243 handlers and 0 bare clauses; the four added for domain diversity contribute 599 handlers and the 1 re-raising bare clause.

Result: the trivial baseline behaves differently across these corpora. Table 7 contrasts the selected packages. Finding density is 21.0% (476/2,270) in the main corpus, 15.6% (38/243) in the four-package control core, and 18.3% (154/842) across all eight control packages. These are descriptive densities in purposively selected corpora, not estimates for broader classes of software. `flake8 --select E722` returns 134 candidates on the main corpus, including all 12 original DEFECT-labelled sites; on the control corpus it returns one candidate, which is a re-raise and carries no DEFECT label.

Result: no misses were identified in the recorded read set. Of the control corpus's 243 handlers the tool reports 38; 114 unreported handlers contain a `raise` and need no review; the remaining 91 silent-and-unreported handlers were each read. None was classified as a miss under the stated protocol: the cases were optional-import and capability probes, `StopIteration` protocol handling, `dict.get` and `list.index` sentinels, documented best-effort fallbacks (`requote_uri`, `get_unicode_from_response`), data-model protocol returns (`NotImplemented`), and CLI exit paths. This is an exhaustive review of that finite read set in one recorded code-reading pass, not independent human adjudication or proof of zero misses in related code.

The four diversity packages agree. `click` (31 findings, 13 HIGH), `anyio` (45 findings, 1 HIGH), `pydantic` (40 findings, 1 HIGH) and `msgpack` (0 findings) reproduce the pattern: 12 of the 15 HIGH findings are `except Exception` capability probes already covered by `BLE001`/`W0718` (Windows-console shims, stream predicates, `TaskGroup` propagation with explicit re-raise paths). The 3 uncovered HIGH findings are contracts on reading: `click/core.py:161` is a `list.index` probe returning infinity as the documented sort key; `click/types.py:269` converts the user's `ValueError` via `self.fail`, which raises `UsageError` — the exception escapes through a call rather than a `raise` statement, a shape no callee-local rule can see (the detector's `exception_escapes` check looks only for the exception object in a returned value or a side-channel call; we refer to this as the `exception_escapes` case); `pydantic/v1/_hypothesis_plugin.py:125` is a `contextlib.suppress(Exception)` digit search in hypothesis test-support code, confirming the SIM105-adjacent blind spot of Section 5.1 from the other side.

Another case the handler-local view cannot decide. `connectionpool.py:812` names a new false-positive mechanism: **state-flag amplification**. The finding is `clean_exit = False` (set alongside `release_this_conn = False`), a control-flow flag consumed in `finally` and after the handler; the `amplifies` criterion ("the value outlives the call") promotes it to HIGH exactly as it would a substituted return value. Telling the two apart requires knowing where the variable is consumed, which lies outside the handler. Like the `exception_escapes` case above and the three constructed probes in the Discussion, it is retained in the frozen evaluation so that the tested build's mistakes remain reproducible. These are limitations to address in later detector versions, not reasons to retain incorrect behaviour. A subsequent repair should be evaluated against this record without rewriting the original observations.

5.3 RQ3: Candidate validity and the scope of local analysis

A coverage boundary establishes what a warning system reports. To ask whether the uncovered code needs repair, we examine exploratory contract readings and public change records. These sources have different selection processes and cannot be pooled into a defect-rate estimate.

5.3.1 Exploratory labels on sampled findings

Method. We drew a stratified random sample across (rule × package), with fixed seed 20260831, at least one draw per stratum, and proportional allocation of the remaining draws; the sample contains $n = 80$ findings. The draw came from an earlier 659-candidate export. Review then identified ten false-positive `implicit-fallback` findings, leaving a 649-candidate corrected frame; the four sampled

Table 7: Style-opposite corpora, same detector build and baseline selection. Densities are findings per handler inside the scan roots. The E722 row reports coverage of the original 80-item LLM-labelled sample only; one supplementary LLM DEFECT label lies outside E722. Control-corpus classifications come from one recorded code-reading pass, not independent human adjudication, and use a different process from Group A.

	Group A	B core (4 pkgs)	B all (8 pkgs)
Handlers	2,270	243	842
Bare `except:`	134	0	1 (re-raise)
Findings	476 (21.0%)	38 (15.6%)	154 (18.3%)
HIGH	208	6	21
Unique HIGH (`covered_by` empty)	25	2	5
E722 candidates	134	0	1
E722 coverage of original 80-sample labels	12/12	—	—
Recorded DEFECT labels	12/80 + 1/60	0 of 38	0 of 38, 0 of 15 new HIGH

findings from that rule were all false positives and are not included in the frame projection below. Weighting the remaining 76 observations by stratum size gives a projection of 130 LLM DEFECT labels (20.0%) in the 649-candidate frame. This is a projection of labels, not confirmed defects, and we make no claim about confirmed-defect prevalence. The 28 further precision fixes that produced the v0.8.0 frame removed four additional sampled CONTRACT findings; only 72 of the original 80 labels remain in that frame, and this surviving subset is not representative of the current 621-finding set.

The unweighted 12/80 share describes only the drawn sample. Each sampled finding was assigned one of three labels by reading nearby source in the pinned tree: **DEFECT** (the converted failure produces a wrong caller-visible outcome with no signal), **CONTRACT** (the behaviour appears deliberate and is documented, commented, or expressed in the return type), or **FALSE POSITIVE** (the detector is wrong about the code).

Labelling was performed by LLM agents. Two rounds were run, both by LLM agents (not human raters), and they agreed on 80/80 items. This agreement is compatible with shared model bias; it does not establish label accuracy or independence. The artefacts establish two separate runs, not independent human adjudication. What is committed is both label sets — `paper/annotations.csv` (first round, rationales recorded in Chinese) and `paper/annotations-second-pass.csv` (second round, rationales in English) — so the agreement can be checked item by item rather than taken on trust. The sample remains useful as (a) a debugging instrument (Section 5.3.4) and (b) the consequence arm of the triangulation in Section 5.3.3, where its limits are part of the design.

Meaning of a DEFECT label. DEFECT denotes the frozen LLM judgement, not an independently confirmed failure-routing mechanism. Five of the twelve original labels concern a discarded comparison and an unassigned state; their failure-conversion mechanism is unestablished. The other seven have the mechanisms described in Section 7. We retain the original labels for reproducibility; they do not establish defect yield.

Result (80 sampled findings, LLM-labelled). Table 8 reports the sample labels; Tables 9 and 10 show their distribution by rule and package. All counts describe this sample; they do not establish a package-level or corpus-wide defect rate.

Table 8: LLM-assigned labels in the original 80-finding sample. Frequencies describe this sample and are not a defect-rate estimate.

LLM label	n	Share of sample
CONTRACT	64	80.0%
DEFECT	12	15.0%
FALSE POSITIVE	4	5.0%

Table 9: LLM labels by detector rule in the 80-finding sample. All twelve DEFECT labels are in `silent-fallback`; all four FALSE POSITIVE labels are in `implicit-fallback`.

Rule	n	DEFECT	CONTRACT	FALSE POS.
`silent-fallback`	49	12	37	0
`no-action`	23	0	23	0
`implicit-fallback`	4	0	0	**4**
`silent-suppress`	3	0	3	0
`masked-exception`	1	0	1	0

Table 10: LLM labels by package in the original 80-finding sample. All twelve DEFECT labels are in `deepteam`; all four FALSE POSITIVE labels are in `implicit-fallback`. Counts are descriptive of this sample.

Package	n	DEFECT	CONTRACT	FALSE POS.
deepteam	14	**12**	1	1
inspect_ai	41	0	40	1
pydantic_ai_slim	11	0	10	1
trl	4	0	4	0
garak	3	0	3	0
fickling	3	0	2	1
smolagents	2	0	2	0
uqlm	2	0	2	0
all but deepteam	66	**0**	63	3

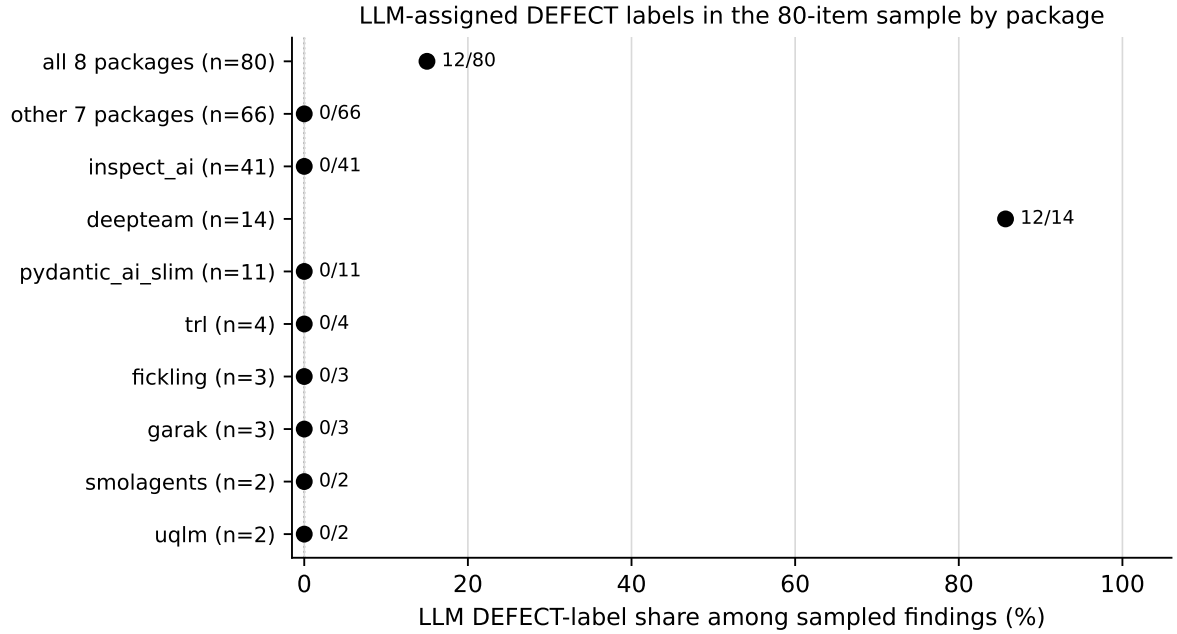


Figure 3: Share of sampled records assigned the LLM DEFECT label by package. The plotted shares and counts describe the 80-item sample; they are not package-level defect-rate estimates.

All 12 DEFECT labels are in `deepteam`; none of the 66 sampled findings from the other seven packages carried that label. These are sample counts, not evidence that the other packages have zero defects.

The 12 DEFECT-labelled sites are not 12 independent observations: they fall into three repeated code families:

1. **Silent criteria degradation (4/12).** A handler catches an error from `model.get_system_prompt()` and assigns an empty string. If a custom or misconfigured model lacks that method, later evaluations may run without the intended criteria. The author's issue on this pattern predates the LLM labelling pass; it is not independent validation of the label.
2. **Discarded comparison (5/12).** A handler evaluates `self.score == 1` but discards the result, then assigns `self.success = False`. The conversion mechanism is unestablished: the observed score values did not raise, although attribute access or overloaded equality can raise for other objects.
3. **Potentially fail-open security verdict (3/12).** A handler catches an error while iterating results and returns `vulnerable = False`. In a red-teaming tool, this could turn an operational failure into a false `not vulnerable` result; this interpretation remains an LLM label, not an independent adjudication.

Handler forms in the labelled sample. The 80 sampled findings include 13 bare `except:` handlers; 12 carry DEFECT labels. The remaining forms are 18 `except Exception:` handlers, 46 narrowly typed handlers, and 3 `contextlib.suppress` sites; none in these groups carries an original DEFECT label. These counts are descriptive of the sample. The three findings in the suppress group are too few to support a useful comparison, and all labels retain the limitations above.

Sensitivity to repeated findings. The twelve original DEFECT labels come from three repeated function families. The unit used to group copies changes the descriptive share: grouping by package and enclosing function gives 3 of 68 groups (4.4%); grouping by exact signature gives 5 of 71 (7.0%); grouping by package, file, and function gives 12 of 78 (15.4%), because copies in separate files remain separate groups. No one grouping is established as the correct independent unit. These sensitivity counts reinforce that the 12/80 observation-level share is not a confirmed-defect rate, and the 20.0% stratum-weighted projection does not correct for within-family repetition.

The 64 CONTRACT labels include TUI widget lookups that may not be mounted, optional-dependency probes, idempotent cleanup in `finally`, and predicate functions whose `Optional/bool` return type is part of the contract. Some have comments that state the intended fallback; the label itself remains an LLM judgement.

Two sampled `pydantic-ai` handlers illustrate why local shape alone is insufficient: one returns `True` for an unparseable address, while another places a caught exception on a queue for the consumer to re-raise.

5.3.2 Curated merged fixes and construct scope

A curated reference set of upstream fixes in this defect family is available; the projects' maintainers reviewed and merged those changes. This is not an exhaustive defect census or an independent adjudication of every merge. Of the 75 pull requests submitted from the author's account that were merged *as of the 2026-09-01 measurement freeze*, **16** are failure-routing fixes — every exclusion adjudicated by reading the PR diff (52 earlier title-only judgements were re-checked against diffs in a dedicated pass; 49 stood, 3 flipped). For each family fix, the file was fetched at the merge commit's *first parent* (i.e. immediately pre-fix) and scanned. Table 11 classifies the 16, and every pull request is cited with its repository owner so that the classification can be checked against the public record.

In the curated reference set, the detector matches 3 of 14 in-scope fixes (21.4%). At most 5 of 14 (35.7%) use a handler shape potentially reachable by this detector; nine of 14 (64.3%) route failure outside an except-handler. This is coverage of the curated set, not a population recall estimate. Figure 4 plots the split by defect family.

This is the construct-scope result for the curated reference set. It shows that the failure-routing cases in that set include patterns outside the local exception-handling subfamily this tool operationalises. We state this as a boundary *and* a roadmap — dataflow-shaped failure-routing is future work — and scope the detector's results to handlers and `contextlib.suppress` sites accordingly.

Detection on merged fixes in the failure-routing reference set

Repository	PR	Detected	Rule	Note (abridged)
uqlm	#462	NO	—	miss reason: pre-fix defect is NaN produced by exhausted retries reachi...
inspect_ai	#5068	NO	—	miss reason: handler converts failure via post-handler state mutation (...
uqlm	#459	NO	—	miss reason: failed judge's NaN entered panel aggregates via data flow,...
PyRIT	#2466	NO	—	miss reason: unresolvable techniques were dropped by silent list filter...
PyRIT	#2460	N/A	—	TypeScript (web UI); failroute is Python-only -> out of language scope
uqlm	#450	**YES**	no-action	matched: uqlm/utils/response_generator.py:252(no-action)
inspect_ai	#4906	NO	—	miss reason: failure masking lives inside tenacity retry semantics (opa...
inspect_evals	#2167	NO	—	miss reason: broken invariant was converted to Score(value=0.0) by an o...
unstructured	#4438	NO	—	diff-read J1 FLIP: pre-fix decoded file-like objects with errors="ignor...
PyRIT	#2309	NO	—	diff-read J1 FLIP: unmapped braille symbols were silently dropped, corr...
trulens	#2653	**YES**	no-action	diff-read J1 FLIP: pre-fix silently normalized out-of-scale JSON scores...
uqlm	#425	NO	—	miss reason: pre-fix code crashed (ZeroDivisionError propagated); the f...
uqlm	#418	N/A	—	pure-additive fix; pre-fix defect is a non-handler implicit-None (funct...
agent-sweep	#195	NO	—	H-batch (family yes, diff-read): _write_text swallows OSError and calle...
agent-sweep	#197	**YES**	silent-fallback	H-batch (family yes, diff-read): unparseable lines / unreadable files s...
inspect_ai	#4908	NO	—	H-batch (family yes, diff-read): malformed multi-letter GRADE verdicts ...

In-scope matches: 3/14 = 21.4%; two cases are out of scope.

Figure 4: Matches in the curated merged-fix reference set. Shaded rows are matched; N/A denotes the two out-of-scope cases. Repository and pull-request identifiers locate each public change. This is not an estimate of population recall.

Table 11: Classification of the 16 family fixes (`paper/merged-pr-recall.csv`, all rows diff-read). "Handler-shape gap" means design-reachable: a shape outside the current six that could be expressed without changing the handler-level design.

Class	n	Cases
Out of scope for recall	2	`microsoft/PyRIT#2460`, a TypeScript-side change (language scope); `cvs-health/uqlm#418`, a pure-additive *Python* fix whose pre-fix defect is a non-handler implicit-`None` contract violation the six rules do not cover by design
Detected	**3**	`cvs-health/uqlm#450`, `Ishannaik/agent-sweep#197`, `truera/trulens#2653`
Handler-shape gap	2	`UKGovernmentBEIS/inspect_ai#5068` (post-handler state mutation), `#4906` (`tenacity` RetryError masking) — both adjudicated as candidate patterns, not shipped
Non-handler routing	**9**	NaN values reaching aggregates, silently filtered lists, branch-level `Score(0.0)` returns, implicit-`None` contract violations, silently stripped characters, silently dropped symbols, laundered verdicts

Side observation. In the pre-fix `UKGovernmentBEIS/inspect_ai` #5068 file the detector flagged a *different, unfixed* `silent-fallback` candidate at line 356. That finding was not adjudicated as a defect in this recall audit.

5.3.3 Comparing three sources of validation evidence

The original sample contains many CONTRACT and FALSE POSITIVE labels, but those are LLM judgements rather than independent defect adjudications. The remaining question is whether maintainer behaviour can distinguish deliberate contracts from defects that have not been noticed. We compare three evidence sources that measure different, non-commensurable populations. Table 12 sets out what each source records.

Table 12: Three evidence sources and the finite records each describes. The datasets behind arms 2 and 3 are described below.

Arm	Question	Observed record
1 — consequence labels	What did the LLM rounds label in the stratified sample?	12/80 (15.0%) DEFECT labels, all in one package
2 — spontaneous maintainer action	What was changed during the tracked window?	13/478 (2.7%) tracked sites classified FIXED
3 — maintainer response	What happened to the selected family-fix PRs?	16/43 (37.2%) selected PRs merged

Records behind arms 2 and 3. Arm 2 is a maintainer-behaviour dataset over the same eight pinned packages, published as `paper/arm2-tracked-sites.csv`. The pipeline behind it tracked 2,128 `try` sites across ten releases of each package and labelled 478 of them FIXED/SURVIVED, discarding 1,650 (77.5%) as too young (924), vanished (681) or mutated (45); none of the 13 FIXED sites traces to a PR submitted from the project account — the 9 PR-attributed fixes match no PR in that account's record, and the 4 unattributed ones were cleared by package and content check. Two properties of that population bound what arm 2 can be compared against. Its tracking criterion (a handler carrying no raise, log or warn signal) is weaker than the six rules of Section 3, so only 185 of the 478 rows (38.7%) carry a `failroute` rule at the release where they were first observed. And its package mix is 59.4% `deepteam`, against 22.5% of the 621 findings. Arm 3 is the merged/closed record of family fix PRs submitted from the author's account: the 16 merged members are itemised in `paper/merged-pr-recall.csv` — 8 of them in packages outside the tracked eight — and the 27 closed-unmerged members are itemised, with per-PR closure reasons, in `paper/h1_arm3_classification.csv` (copied into this artefact set from the unreleased companion repository so the composition is third-party checkable): 19 self-closed, 1 bot-closed, 3 closed without reaching the merits, 2 substantively accepted, and 2 adverse on the merits. Among the 24 PRs not self-closed, 16 merged, seven were maintainer-closed, and one was bot-closed. One closed PR (`cvs-health/uqlm`#427) shares its substance with merged PR #462, and two others

duplicate separate submissions; therefore the 43 PRs are not 43 distinct candidate defects. These are descriptive outcomes in a project-selected set, not an acceptance-rate estimate.

Evidence interpretation. The arms distinguish three activities: labelling consequences, tracking maintainer changes, and evaluating submitted reports. Their denominators and selection processes define different questions. Arm 2's criterion is weaker than the detector's; 61.3% of its rows have no `failroute` rule, and its package composition differs from the candidate frame. A SURVIVED site may be an intentional contract or an unnoticed defect. Transferring arm 1's labels onto this risk set would therefore assume both compatible sampling and defect adjudication that the records do not supply.

Correspondence and maintainer response. None of the 16 merged family fixes maps to the 478 tracked sites (zero exact file matches). In `uqlm`, none of 12 tracked family sites was classified FIXED, while all five project-selected family-fix PRs were merged; these remain different selected sets. The PR record shows substantial, but uneven, maintainer engagement: among 24 non-self-closed outcomes, 16 merged, seven were maintainer-closed and one was bot-closed. Two additional closures accepted the substance: the gap in `Giskard-AI/giskard-oss`#2614 was fixed through a third-party restatement, and `cvs-health/uqlm`#427 was partially re-landed through merged #462. Three closures did not reach the merits and two were adverse on the merits. Duplicate submissions also prevent treating all 43 PRs as distinct defects.

Implication for validation design. The itemised records let readers audit selected classifications and maintainer responses, but cannot be combined into a common defect rate. A matched study would independently adjudicate contracts for a randomly selected set of detector and baseline findings, retain their identities through maintainer follow-up, and account for vanished and mutated sites. That study would address the specific correspondence and risk-set gaps identified here; it cannot be reconstructed from the present records.

5.3.4 Candidate review as a check on the instrument

All four false positives in the sample were `implicit-fallback`, and all four had the *same* root cause: `_has_top_level_terminal()` inspected only *direct* statements of the handler body, so a `return`/`raise` nested inside an exhaustive `if/else` was invisible. Table 13 lists the four real shapes that triggered it.

Table 13: The four shapes that exposed the detector bug.

Package	Function	Shape
deepteam	`simulate_baseline_attacks`	`if ignore_errors: return [...] else: raise`
fickling	`check_pickle`	nested `try/except`, every path returns
inspect_ai	grok `generate`	`if/elif/else`, every branch returns or raises
pydantic_ai	`execute_output_function`	`if wrap: raise ToolRetryError else: raise`

We implemented a recursive exhaustiveness analysis (`_always_terminates`) covering `if/else`, `with`, `try/except/finally` and `match`, added six regression tests derived from the four real shapes (each failing before the fix), and re-ran the corpus.

`implicit-fallback` findings on the 524,229 lines the detector actually reads: 10 → 0. Total findings: 659 → 649 (v0.7.0). The v0.8.0 precision release removed 28 more findings through four audited fixes (tuple-typed handlers, `warnings.warn` recognised as a signal, `StopAsyncIteration` added to the ignore list, conservative optional-dependency probe): **649 → 621**, with every deletion traceable to a labelled category or a mechanical criterion — no labelled DEFECT was removed. The test suite grew over the same period, from 124 to 130 (the six regression tests of this subsection) and then to **158** (twenty-eight more with the v0.8.0 precision release).

The corrected recursive control-flow analysis reduced this rule's ten candidates in the corpus to zero; the four sampled false positives exposed the shared cause. More broadly, the stratified labelling pass revealed a detector defect that the unit fixture corpus did not expose.

6 Discussion

Coverage is a property of a comparison. The measured overlap depends on the representation the detector recognises, the semantics of the selected baseline rules, and the files each tool actually reads. The suppression witnesses isolate a representation boundary; the 68 probes isolate rule differences; the Pylint file-list check isolates a harness omission. An unmatched warning is therefore an observation about this comparison. Establishing an additional defect requires separate contract evidence.

Refinement and calibration answer different questions. The detector refactor changes candidate identities and severities. Calibration leaves all 476 outputs unchanged but corrects the predicted unmatched share by 28.8 percentage points. Combining these changes into one improved-detector result would conceal which mechanism changed the measurement. Paired exports, stable coordinates and an executed coverage check allow the two effects to be reported separately.

A simple baseline is a necessary comparator. On the main corpus, `flake8 --select E722` yields 134 candidates containing all twelve original DEFECT-labelled sites. One supplementary DEFECT label lies outside E722, but it comes from the same LLM process. On the selected infrastructure control corpus, E722 yields just one re-raising handler. These observations show why a comparator's candidate set and the source style matter; the records do not establish a true defect yield for either detector.

Caller intent is the remaining validation problem. A return type may admit `None` or `False` without making an operational failure equivalent to a legitimate value. Conversely, a constant fallback may be intentional. This study does not recover caller intent through a call graph. Three constructed probes against the frozen 0.9.1 build illustrate the boundary: a typed handler returning `False` on a database timeout and an `Optional`-returning function returning `None` on a Redis error are missed, while a validation loop with a `return False` handler is reported at HIGH. The state-flag and `exception_escapes` cases in Section 5.2.1 add further examples. They motivate independent contract adjudication rather than another assumption about local shape.

Validation sources must keep their own denominators. Copied function families cluster the original labels; tracked sites omit some detector gates and suppress constructs; project-selected PRs include self-closures and fixes outside the tracked packages. Survival can mean lack of action, and a merge can mean acceptance of a change without a defect judgement. Reporting these sources separately preserves the useful evidence without transferring a label share or merge share to another population.

An evaluation procedure. For a future failure-routing detector, the findings support four concrete checks: lock the corpus and verify each tool's read set; calibrate inferred coverage with executed positive controls; report candidate identities and absolute counts when the predicate changes; and adjudicate caller contracts independently on a sample kept separate from development. The first three are exercised here. The fourth is the missing evidence for a claim about incremental defect detection.

7 Threats to validity

Construct and measurement validity. Co-location within one line does not establish that two tools diagnose the same property; a farther warning may still be relevant. The supplementary Semgrep rule was developed within this project. The detector operationalises local handlers and suppress statements, while nine of 14 in-scope curated fixes lie outside those constructs. Its known false-positive and false-negative modes remain in the evaluated build. All measurements describe pinned versions, not current ecosystem-wide behaviour.

Label validity and reproducibility. The 80 stratified and 60 supplementary labels were produced by LLM agents, not human raters. The two original runs agreed on 80/80 items, but shared model bias can produce that agreement. Model identity and version were not recorded and could not be recovered, so the labels and rationales can be inspected but the annotation process cannot be reproduced bit for bit. Five original DEFECT labels have an unestablished conversion mechanism: the `try` body evaluates `self.score == 1` and discards its result. Tested values did not raise, although other objects' attribute access or equality could. The pinned `is_successful` function has no caller, and initial state depends

on an external `BaseMetric` implementation unavailable in the reproduction environment. Those labels remain in the frozen record; they do not confirm failure-to-value defects.

Sampling and development reuse. The original draw was from 659 v0.7.0 candidates; only 72 of its 80 coordinates survive into the 621-finding frame, so the retained observations are no longer a random sample of that frame. Cells are small, including one `masked-exception` observation. The eight main packages were selected because of the author's contribution history, and a candidate family in `deepteam` had already been reported from that account. All twelve original DEFECT labels occur in that package and three copied families. The refined predicate used the same corpus and all 140 labels during development, and the supplementary labels deliberately sample changed sites. Its label disposition is in-sample evidence, with no held-out estimate of defect-detection performance.

Control-corpus adjudication. The main and control corpora represent two purposively selected Python styles. The 38 core findings and 91 unreported handlers received one recorded code-reading pass; history, issue and test evidence was collected only for the two unique HIGH findings. The remaining readings rely on source contracts, docstrings, guarded uses, fallback comments and re-raise paths. Borderline cases with documented policies were assigned CONTRACT. The fifteen additional HIGH findings likewise received a single reading. These records establish neither independent human adjudication nor defect prevalence in infrastructure code.

Maintainer records and selection. The reference set consists of sixteen family-related merges from the author's account; per-PR divisions of AI-assisted work are undocumented. Family inclusion was checked from diffs, including a recheck of 52 earlier title-based decisions that changed three classifications. The separate 43-PR record includes nineteen self-closures, one bot closure, sixteen merges and seven maintainer closures; two submissions duplicate others and one overlaps a counted merge. Eight merges are outside the tracked packages. Acceptance of a change does not establish its defect status or representativeness.

Tracking and inference. The tracking pipeline retains 478 of 2,128 sites after excluding 924 young, 681 vanished and 45 mutated sites. This risk set is a reporting convention. Only 185 retained sites carry a detector rule, because tracking omits the three exemption gates, fallback-value analysis and suppress constructs. A SURVIVED site records that nobody acted, not that the behaviour is intentional. Findings, tracked sites and PRs use different units and selected populations. The paper therefore reports their finite-set observations separately and makes no population-level defect or acceptance claim.

8 Related work

Python exception handling and anti-pattern detection. Cabral and Marques [7], Sawadpong et al. [20] and de Pádua and Shang [4, 5] established exception handling as an empirical object. Python is also covered by recent work. Exception Miner uses static AST queries to identify handling anti-patterns in Java, TypeScript and Python, and was evaluated on eleven multi-language projects [22]. Souza et al. [24] subsequently analysed 942 manually validated Python exception-handling bugs from 550 projects, including machine-learning and AI software, and derived root-cause and repair taxonomies. Their categories include swallowing, overly broad handling and incorrect recovery actions. These studies provide a broader account of handling practices and bugs than the corpus used here. Our research question concerns the sensitivity of a detector's measured overlap to representation, candidate predicates and the evaluation harness.

Warning measurement and actionability. Developers' use of static analysis depends on noise and actionable feedback [8, 11, 16, 25]. Tricorder and FindBugs-Fixit describe filtering and prioritisation in deployed analysis [3, 17, 18]; work on false-positive mitigation and warning relevance gives further context [9, 15]. Hu et al. [10] study developers' suppression of static warnings. A warning-suppression annotation and a runtime `contextlib.suppress` statement operate at different layers: the latter changes exceptional control flow. Our suppression witnesses measure which tested rules reach that runtime construct. The calibrated coverage map supplies executed checks on a warning comparison; it does not establish relative actionability or superiority over every exception-handling tool.

LLM support and contract validation. Souza et al. [23] evaluate prompted LLMs on four Python exception-handling tasks: identifying need, locating protected statements, recommending exception types and generating handlers. Their design tests model outputs against a curated benchmark. Here the LLM readings are retained exploratory labels with unrecoverable model provenance. They help expose candidate interpretations and instrument errors, but cannot support a claim of independently measured defect precision.

Failure signals in ML and evaluation pipelines. Pipeline coupling and boundary checks motivate software-level reliability work in ML [1, 6, 13, 14, 19, 21]. Rollout Cards [12] already documents reward exceptions converted to ordinary numeric scores and changes to aggregation denominators in agent-evaluation repositories. Our study examines local Python constructs and the measurement of their warning coverage. The new evidence is the suppression-form boundary, the 68-probe rule calibration and the paired frame comparison; the general failure-to-value problem and the presence of exception-handling anti-patterns are established concerns.

9 Conclusion

This study provides a reproducible evaluation of local failure-routing analysis across eight pinned AI/ML Python packages. The 621-candidate frame exposes a suppression-form gap in the tested lint configurations; 68 generated probes calibrate a corrected coverage mapping that agrees with executed baselines on the 476-finding refined frame. These results show how source representation, rule semantics and file discovery affect measured incremental warning coverage.

Predicate refinement reduces the candidate count from 621 to 476 while co-location rises from 41.1% to 52.9%. The curated fix set complements this comparison by locating nine non-handler cases among 14 in-scope fixes, specifying a boundary for extending the analysis beyond local handlers. Together, the measurements provide concrete tests and an explicit evaluation procedure for future detectors.

Defect yield remains a separate validation question. The available labels were produced by LLM agents and reused during development; the original DEFECT-labelled observations also occur within a simple E722 baseline. Independent contract adjudication on held-out packages, including findings from both the detector and simple baselines, is the next step needed to measure incremental defect detection.

A Reproduction and artefacts

The empirical counts and comparisons are generated from scripts in `tools/` against the pinned corpus in `paper/corpus-lock.json`; label and classification records are retained in the accompanying ledgers. All paths below are relative to the root of the public repository https://github.com/feiiiiii5/failroute (MIT licence); the detector itself is released as `failroute` on PyPI, https://pypi.org/project/failroute/. The baseline analyses use `failroute` 0.8.0; the refinement comparison uses 0.9.1. The pinned commit `3b4c567` contains the underlying datasets, exports and scripts for the reported numerical results, including the post-release ledgers and corrected baseline invocation. The figure PDFs in this submission have later layout edits but unchanged plotted counts; they are included in the manuscript source package. The v0.8.0 release tag alone does not reproduce every table. The committed `bench/rescan-f2/` export records the 621-finding frame; `bench/rescan-v2/` records the 476-finding refactored frame (freshly reproduced 2026-09-07).

The pinned 0.8.0 suite contains 158 tests; the 0.9.1 release contains 221 tests. All 15 release test jobs across Ubuntu, macOS and Windows and Python 3.9–3.13 passed, along with the quality job. The 0.8.0 unit corpus v6 has 36 positive and 32 negative fixtures. For 0.9.1, the revised 34/34 fixture set is labelled v7; five narrow-type `contextlib.suppress` cases changed to negative and three other cases changed in the opposite direction. Every corpus scan reported here was run on macOS arm64; the CI matrix exercises tests, not scans.

```
git clone https://github.com/feiiiiii5/failroute && cd failroute
git checkout 3b4c567                # pinned commit: every artefact the tables use
python -m venv .venv && . .venv/bin/activate
pip install '.[test,paper]'   # pytest + matplotlib + 4 linters + bugbear
python tools/fetch_corpus.py         # pinned sdists -> paper/corpus/
    # version+sha256 pinned in paper/corpus-manifest.json; fetch verifies each
```

```
    # archive against paper/corpus-lock.json and exits non-zero on mismatch
    # (it rewrites only the lock's generated_at_utc timestamp; the eight
    # archive digests are what must match)
PYTHONPATH=src python -m pytest                    # 221 tests (0.9.1 suite)
PYTHONPATH=src python tools/rescan_corpus.py --out bench/rescan-paper --with-context
    # The detector at this commit is 0.9.1, so a fresh rescan reproduces the
    # refined frame (total 476), not the baseline's 621: the 621 frame belongs to the
    # v0.8.0 detector and is committed as bench/rescan-f2. Writes to bench/;
    # do NOT re-export over paper/scan/, the frozen v0.7.0 baseline.
python tools/coverage_union.py --findings-dir bench/rescan-f2
    # -> bench/corpus-coverage-union.json ; union 255/621 = 41.1%
    # bench/rescan-f2 is the committed 621-finding v0.8.0 export every baseline
    # figure is read from. To reproduce the refined frame's instead, point the same
    # command at bench/rescan-v2 (or your own --out above): union 252/476 =
    # 52.9%. The default --findings-dir paper/scan is the frozen v0.7.0 set,
    # whose union figure is deprecated.
python tools/coverage_union.py --ruff-select S110,S112,BLE001 \
    --findings-dir bench/rescan-f2 --out /tmp/union-symmetric.json
    # the symmetric baseline variant quoted in RQ1 (ruff also gets its
    # broad-except rule): ruff 127 co-located, union 255/621 = 41.1% ---
    # the same union the narrow selection gives, as RQ1 explains;
    # committed as bench/corpus-coverage-union-ruff-ble001.json
python tools/make_figures.py                       # -> paper/figures/ (3 figures;
    # pinned code uses earlier layout, with the same plotted counts)
python tools/j1_adjudicate.py              # diff-read family adjudication
```

Reproducing the paired measurements.

```
.venv/bin/python tools/rescan_corpus.py --out bench/rescan-v2 --with-context
.venv/bin/python tools/coverage_union.py --findings-dir bench/rescan-v2 \
    --out bench/corpus-coverage-union-v2.json \
    --emit-per-finding bench/corpus-coverage-per-finding-v2.jsonl
.venv/bin/python tools/coverage_union.py --findings-dir bench/rescan-f2 \
    --out bench/corpus-coverage-union-621frame.json \
    --emit-per-finding bench/corpus-coverage-per-finding-621.jsonl
.venv/bin/python tools/e722_baseline.py        # -> bench/e722-baseline.json
.venv/bin/python tools/rq5_refactor_delta.py   # -> bench/rq5-refactor-delta.json
PYTHONPATH=src .venv/bin/python tools/lint_mapping_probe.py --check-parity
    # -> bench/lint-rule-mapping.json; re-runs all four baselines over 68
    # generated probes and exits non-zero if the shipped covered_by table
    # drifts from what those baselines actually do
.venv/bin/python tools/pinned_rescan.py --out /tmp/pinned-v080
    # -> re-scans the pinned corpus with the v0.8.0 detector, from a git
    # worktree at that tag, using that tree's own src and exporter; prints
    # PINNED_TOTAL=621 plus the per-rule and per-package counts. This is what
    # the claims asserting v0.8.0's historical scan results now run through.
PYTHONPATH=src .venv/bin/python tools/refix_replay.py
    # -> rebuilds the pre-correction covered_by_for in a scratch tree and runs
    # the 36 mapping tests against it; prints REFIX_REPLAY 21 failed, 15
    # passed. The fail-to-pass half of the correction's evidence.
```

The checked-in exports make both frames reproducible without overwriting the frozen v0.7.0 scan: `bench/rescan-f2/` contains the 621-finding v0.8.0 frame, and `bench/rescan-v2/` contains the 476-finding refactored frame. Running the corresponding `coverage_union.py` commands reproduces the reported per-rule and per-tool counts.

Reproducing the control corpus.

```
PYTHONPATH=src .venv/bin/python tools/control_rescan.py --check
```

```
# -> verifies bench/control-rescan/<pkg>.jsonl against a fresh fetch
# (SHA-256 checked per paper/corpus-lock-control.json) and re-scan;
# prints CHECK-OK per package, exits non-zero on any drift.
```

Three further pipeline commands are deliberately *not* part of the reproduction path, because each overwrites a hand-curated artefact without regenerating it faithfully: `draw_sample.py` (the committed `paper/sample.jsonl` was drawn from the pre-fix 659 frame; re-drawing changes which 80 findings the published labels describe), `merged_pr_recall.py` (drops the hand-written `note` column), and `compare_linters_corpus.py` (drops the merged semgrep results). See `paper/ARTIFACT.md` §0.2 and §5.5–5.6 before running any of them.

Key artefacts, and the thing each one pins down:

- `paper/corpus-lock.json` — pinned inputs.
- `paper/sample.jsonl` — the 80-item draw.
- `paper/annotations.csv` — labels and rationale.
- `paper/annotations-second-pass.csv` — second automated pass.
- `paper/merged-pr-recall.csv` — curated merged-fix reference set (all rows diff-read). The repository and PR number, rather than the descriptive `pr_title` field, identify each change: the stored titles for `agent-sweep#197` and `inspect_ai#4908` do not match their final GitHub titles. The discrepancy does not alter classification or counts.
- `paper/j1-trulens2653-prefix.py` — pre-fix evidence for the `trulens#2653` detection.
- `bench/corpus-coverage-union-5tool.json` — cross-tool coverage including the self-written semgrep rule.
- `paper/intervals.json` — sample counts used by Figure 3; auxiliary interval calculations in the file are not reported as inferential results.
- `paper/annotations-v2-additions.csv` — the 60 supplementary labels of Section 5.2, with rationale, enclosing signature, the detector's own severity / isomorphism / `covered_by` values, and a flag for whether the site is new in the refactored frame; the two frozen annotation files above are unchanged.
- `bench/corpus-coverage-per-finding-v2.jsonl` — the refactored 476-finding frame, one row per finding, carrying severity, isomorphism class and both coverage classifications.
- `bench/corpus-coverage-union-v2.json` — the aggregate of that run: 476 findings, 252 covered, 224 `failroute`-only.
- `bench/corpus-coverage-per-finding-621.jsonl` — the same per-finding export for the v0.8.0 frame, regenerated from the in-tree `bench/rescan-f2/` so that RQ1 no longer depends on a scratch directory.
- `bench/corpus-coverage-union-621frame.json` — the aggregate of that run: 621 findings, 255 covered, 366 `failroute`-only, matching `bench/corpus-coverage-union.json` cell for cell.
- `bench/e722-baseline.json` — the E722 and BLE001 candidate counts and their overlap with the labelled defects.
- `bench/rq5-refactor-delta.json` — the frame difference and the label disposition under the refactor.
- `bench/lint-rule-mapping.json` — the measured matrix of which lint rule fires on which handler kind and body shape, from `tools/lint_mapping_probe.py`. This is the evidence the `covered_by` table is derived from rather than the table's own assertion.
- `bench/corpus-coverage-per-finding-v2-pre-coverby-fix.jsonl` — the per-finding export as it stood *before* that correction. Preserved rather than regenerated: the over-crediting inference it records no longer exists in the source, so this file is the only record of what the earlier predicted-unmatched figure of 18.3% was computed from, and the before/after comparison is a diff against it.
- `paper/h1_arm3_classification.csv` — the arm-3 closed-PR ledger (160 diff-read rows; 27 family), copied byte-identically from the companion repository.
- `paper/arm2-tracked-sites.csv` — the arm-2 tracked-site dataset: all 2,128 rows over the eight packages with all five labels, the version span and observation count each label rests on, and the PR each FIXED row is attributed to. Projected field-for-field from the companion repository's maintainer-behaviour dataset; code snippets and commit-level attribution are deliberately excluded, so the labels are auditable but not re-derivable from this artefact alone.

Execution notes. The commands use `PYTHONPATH=src` to import the checked-out package reliably across environments. The v0.8.0 scanner exits with status 1 when it reports findings even if the scan and export succeeded; a reproducer must preserve the output and distinguish findings from execution errors. The 0.9.1 scanner provides separate severity and error exit statuses.

Availability and ethics. The corpus is eight publicly distributed PyPI source distributions, each used under its own licence; nothing was taken from a private source. The maintainer-behaviour record is a set of public GitHub issue and pull-request records, every one cited by its public number, and the two datasets derived from them are committed to the public repository and itemised in the list above, so that the classification can be audited row by row. The study analyses publicly recorded artefacts of professional work on public repositories, and uses no non-public data about identifiable individuals.

Manuscript licence. This manuscript is licensed under the Creative Commons Attribution 4.0 International licence (CC BY 4.0). The code licence and licences of third-party artefacts remain as stated above.

Conflicts of Interest. The author led the project that produced both the detector under evaluation and one of the five baselines. This relationship is disclosed on the title page, and results unfavourable to the tool are reported alongside favourable ones. The author declares no other conflicts of interest.

References

[1] Saleema Amershi, Andrew Begel, Christian Bird, Robert DeLine, Harald Gall, Ece Kamar, Nachiappan Nagappan, Besmira Nushi, and Thomas Zimmermann. Software engineering for machine learning: A case study. In *2019 IEEE/ACM 41st International Conference on Software Engineering: Software Engineering in Practice (ICSE-SEIP)*, pages 291–300, 2019. doi: 10.1109/ICSE-SEIP.2019.00042.

[2] Astral. Ruff rule SIM105: suppressible-exception, 2026. URL https://docs.astral.sh/ruff/rules/suppressible-exception/. Documentation read 10 October 2026.

[3] Nathaniel Ayewah and William Pugh. The google findbugs fixit. In *Proceedings of the 19th international symposium on Software testing and analysis*, pages 241–252, 2010. doi: 10.1145/1831708.1831738.

[4] Guilherme Bicalho de Pádua and Weiyi Shang. Revisiting exception handling practices with exception flow analysis. In *2017 IEEE 17th International Working Conference on Source Code Analysis and Manipulation (SCAM)*, pages 11–20, 2017. doi: 10.1109/SCAM.2017.16.

[5] Guilherme Bicalho de Pádua and Weiyi Shang. Studying the prevalence of exception handling anti-patterns. In *2017 IEEE/ACM 25th International Conference on Program Comprehension (ICPC)*, pages 328–331, 2017. doi: 10.1109/ICPC.2017.1.

[6] Eric Breck, Shanqing Cai, Eric Nielsen, Michael Salib, and D. Sculley. The ml test score: A rubric for ml production readiness and technical debt reduction. In *2017 IEEE International Conference on Big Data (Big Data)*, pages 1123–1132, 2017. doi: 10.1109/BigData.2017.8258038.

[7] Bruno Cabral and Paulo Marques. Exception handling: A field study in java and .net. In *ECOOP 2007 — Object-Oriented Programming*, Lecture Notes in Computer Science, pages 151–175. Springer Berlin Heidelberg, Berlin, Heidelberg, 2007. doi: 10.1007/978-3-540-73589-2_8.

[8] Lisa Nguyen Quang Do, James R. Wright, and Karim Ali. Why do software developers use static analysis tools? a user-centered study of developer needs and motivations. *IEEE Transactions on Software Engineering*, 48:835–847, 2022. doi: 10.1109/TSE.2020.3004525.

[9] Zhaoqiang Guo, Tingting Tan, Shiran Liu, Xutong Liu, Wei Lai, Yibiao Yang, Yanhui Li, Lin Chen, Wei Dong, and Yuming Zhou. Mitigating false positive static analysis warnings: Progress, challenges, and opportunities. *IEEE Transactions on Software Engineering*, 49:5154–5188, 2023. doi: 10.1109/TSE.2023.3329667.

[10] Huimin Hu, Yingying Wang, Julia Rubin, and Michael Pradel. An empirical study of suppressed static analysis warnings. *Proceedings of the ACM on Software Engineering*, 2:290–311, 2025. doi: 10.1145/3715729.

[11] Brittany Johnson, Yoonki Song, Emerson Murphy-Hill, and Robert Bowdidge. Why don't software developers use static analysis tools to find bugs? In *2013 35th International Conference on Software Engineering (ICSE)*, pages 672–681, 2013. doi: 10.1109/ICSE.2013.6606613.

[12] Charlie Masters, Ziyuan Liu, and Stefano V. Albrecht. Rollout cards: A reproducibility standard for agent research. arXiv:2605.12131, 2026.

[13] Andrei Paleyes, Raoul-Gabriel Urma, and Neil D. Lawrence. Challenges in deploying machine learning: A survey of case studies. *ACM Computing Surveys*, 55:1–29, 2022. doi: 10.1145/3533378.

[14] Neoklis Polyzotis, Martin Zinkevich, Sudip Roy, Eric Breck, and Steven Whang. Data validation for machine learning. In *Proceedings of the Machine Learning and Systems Conference (MLSys) 2019*, 2019. URL https://proceedings.mlsys.org/paper_files/paper/2019/hash/928f1160e52192e3e0017fb63ab65391-Abstract.html.

[15] Louis-Philippe Querel and Peter C. Rigby. Warningsguru: integrating statistical bug models with static analysis to provide timely and specific bug warnings. In *Proceedings of the 2018 26th ACM Joint Meeting on European Software Engineering Conference and Symposium on the Foundations of Software Engineering*, pages 892–895, 2018. doi: 10.1145/3236024.3264599.

[16] Joseph R. Ruthruff, John Penix, J. David Morgenthaler, Sebastian Elbaum, and Gregg Rothermel. Predicting accurate and actionable static analysis warnings. In *Proceedings of the 30th international conference on Software engineering*, pages 341–350, 2008. doi: 10.1145/1368088.1368135.

[17] Caitlin Sadowski, Jeffrey Van Gogh, Ciera Jaspan, Emma Soderberg, and Collin Winter. Tricorder: Building a program analysis ecosystem. In *2015 IEEE/ACM 37th IEEE International Conference on Software Engineering*, pages 598–608, 2015. doi: 10.1109/ICSE.2015.76.

[18] Caitlin Sadowski, Edward Aftandilian, Alex Eagle, Liam Miller-Cushon, and Ciera Jaspan. Lessons from building static analysis tools at google. *Communications of the ACM*, 61:58–66, 2018. doi: 10.1145/3188720.

[19] Nithya Sambasivan, Shivani Kapania, Hannah Highfill, Diana Akrong, Praveen Paritosh, and Lora M Aroyo. "everyone wants to do the model work, not the data work": Data cascades in high-stakes ai. In *Proceedings of the 2021 CHI Conference on Human Factors in Computing Systems*, pages 1–15, 2021. doi: 10.1145/3411764.3445518.

[20] Puntitra Sawadpong, Edward B. Allen, and Byron J. Williams. Exception handling defects: An empirical study. In *2012 IEEE 14th International Symposium on High-Assurance Systems Engineering*, pages 90–97, 2012. doi: 10.1109/HASE.2012.24.

[21] D. Sculley, Gary Holt, Daniel Golovin, Eugene Davydov, Todd Phillips, Dietmar Ebner, Vinay Chaudhary, Michael Young, Jean-François Crespo, and Dan Dennison. Hidden technical debt in machine learning systems. In *Advances in Neural Information Processing Systems 28 (NeurIPS 2015)*, 2015. URL https://proceedings.neurips.cc/paper_files/paper/2015/hash/86df7dcfd896fcaf2674f757a2463eba-Abstract.html.

[22] Jairo Souza, Tales Alves, Robson Oliveira, Leopoldo Teixeira, and Baldoino Fonseca. Exception miner: Multi-language static analysis tool to identify exception handling anti-patterns. In *Proceedings of the XXXVIII Brazilian Symposium on Software Engineering*, pages 741–747, 2024. doi: 10.5753/SBES.2024.3573. URL https://sol.sbc.org.br/index.php/sbes/article/view/30420.

[23] Jairo Souza, Tales Alves, Rodrigo Lima, Ericlecio Araújo, Leopoldo Teixeira, and Baldoino Fonseca. An empirical evaluation of using large language models to recommend exception handling tasks. In *Proceedings of the XL Brazilian Symposium on Software Engineering*, 2026. URL https://leopoldomt.github.io/assets/pdf/2026-sbes-jairo.pdf.

[24] Jairo Souza, Eric Coelho, João Correia, Rodrigo Lima, Leopoldo Teixeira, and Baldoino Fonseca. Exception handling bugs in python: An empirical study of root causes, fix patterns, and anti-patterns. *Information and Software Technology*, 199:108264, 2026. doi: 10.1016/j.infsof.2026.108264. URL https://leopoldomt.github.io/assets/pdf/2026-ist.pdf.

[25] Rahul Yedida, Hong Jin Kang, Huy Tu, Xueqi Yang, David Lo, and Tim Menzies. How to find actionable static analysis warnings: A case study with findbugs. *IEEE Transactions on Software Engineering*, 49: 2856–2872, 2023. doi: 10.1109/TSE.2023.3234206.